

Sicurezza delle Reti – Risposte Dettagliate

Sezione 9.1 – Controllo degli Accessi

1. Perché la sicurezza delle reti è diventata un problema critico rispetto ai primi decenni delle reti di calcolatori?

Nei primi decenni della loro esistenza, le reti di calcolatori venivano utilizzate prevalentemente da ricercatori universitari per inviare e ricevere e-mail e dalle aziende per condividere le stampanti. In quelle applicazioni non si prestava particolare attenzione alla sicurezza. Oggi, milioni di persone usano le reti per fare acquisti, home banking oppure compilare la dichiarazione dei redditi. La sicurezza delle reti è quindi diventata un problema potenzialmente molto vasto perché sono in gioco dati finanziari, personali e sensibili.

2. Quali sono i principali obiettivi della sicurezza delle reti (impedire letture non autorizzate, modifiche, accesso a servizi, autenticazione, etc.)?

La sicurezza delle reti si occupa di:

- Impedire che intrusi riescano a **leggere** (o, peggio ancora, **modificare di nascosto**) i messaggi destinati a terzi
- Impedire che determinate persone possano **accedere a servizi remoti** che non sono autorizzate a usare
- **Accertarsi dell'identità** dei mittenti dei messaggi (autenticazione)
- Impedire l'**intercettazione e la ripetizione** di messaggi legittimi catturati sulla rete
- **Perseguire** chi afferma di non aver mai spedito certi messaggi (non ripudio)

3. Cos'è il controllo degli accessi? Quali benefici porta l'adozione di una politica di controllo degli accessi?

Il **controllo degli accessi** è un processo fondamentale che determina "**chi può fare cosa a cosa**" basandosi su una specifica politica. Questo processo è essenziale per limitare l'accesso a un sistema o alle risorse del sistema in base a criteri che vanno oltre l'identità dell'utente.

I benefici dell'adozione di una politica di controllo degli accessi sono:

- **Attenzione** dell'organizzazione su problemi di sicurezza (presa di coscienza)
- **Allocazione più efficiente** delle risorse per la sicurezza del sistema
- Possibilità di **configurare la sicurezza appropriata** per ciascuna risorsa del sistema in base al ruolo e all'importanza
- Facilitazione delle operazioni di **auditing e testing** del sistema

4. Quali sono i quattro elementi principali del controllo degli accessi?

1. **Soggetti** (utenti e gruppi di utenti) – chi richiede l'accesso
2. **Oggetti** (file e risorse come memoria, stampanti e scanner) – a cosa si vuole accedere
3. **Operazioni** – cosa si vuole fare (leggere, scrivere, eseguire, aggiungere)

4. **Monitor di riferimento** – componente che verifica le regole per concedere l'accesso a un oggetto a un soggetto

5. Cosa sono i diritti di accesso? Quali quattro diritti di accesso vengono menzionati?

I **diritti di accesso** regolano le autorizzazioni degli utenti per ogni risorsa del sistema. Le modalità di accesso possono essere di due tipi: **osservare** o **alterare**. I quattro diritti di accesso menzionati sono:

1. **Eseguire** (execute)
2. **Leggere** (read)
3. **Aggiungere** (append)
4. **Scrivere** (write)

6. Cosa si intende per modalità di accesso "osservare" e "alterare"?

- **Osservare:** permette all'utente di visualizzare o leggere il contenuto di una risorsa (es. leggere un file, visualizzare una directory)
- **Alterare:** permette all'utente di modificare, aggiungere o cancellare il contenuto di una risorsa (es. scrivere un file, cancellare un file, aggiungere dati)

7. Chi è responsabile della definizione dei diritti di accesso per una risorsa?

Il **proprietario della risorsa** è responsabile della definizione dei diritti di accesso. I diritti degli utenti prevalgono sempre sui diritti dei gruppi.

8. Quali tecniche e tecnologie esistono per gestire i diritti di accesso?

Le tecniche e tecnologie menzionate sono:

- Matrici di controllo degli accessi
- Tabelle di capacità
- Liste di controllo degli accessi (ACL – Access Control Lists)
- Controllo degli accessi basato sui ruoli (RBAC – Role-Based Access Control)
- Controllo degli accessi basato su regole
- Interfacce limitate
- Controllo degli accessi dipendente dal contenuto

9. Cos'è una matrice di controllo degli accessi? Come è strutturata?

La **matrice di controllo degli accessi** organizza tutte le informazioni necessarie per l'amministrazione del controllo degli accessi in una matrice con:

- **Righe** che rappresentano i soggetti o gruppi di soggetti (utenti)
- **Colonne** che rappresentano gli oggetti (risorse)
- **Corpo della matrice:** i permessi dei soggetti sugli oggetti (quali operazioni ciascun soggetto può eseguire su ciascun oggetto)

10. Cosa sono le liste di controllo degli accessi (ACL)?

Le **liste di controllo degli accessi (ACL – Access Control Lists)** sono un metodo per memorizzare i **gruppi con i diritti di accesso associati agli oggetti**. Invece di guardare dalla prospettiva del soggetto (come nella matrice), le ACL sono associate a ciascun oggetto e contengono l'elenco dei soggetti (utenti o gruppi) e i permessi che hanno su quell'oggetto.

11. Cosa sono le tabelle di capacità?

Le **tabelle di capacità** (capability tables) specificano le **operazioni che un soggetto può eseguire su un oggetto**. Dal punto di vista del soggetto, una tabella di capacità elenca per ogni oggetto a cui il soggetto ha accesso quali operazioni sono consentite. È il complemento delle ACL: mentre le ACL sono legate all'oggetto, le tabelle di capacità sono legate al soggetto.

12. Cosa significa l'acronimo "AAA"? Quali sono i tre pilastri che lo compongono?

Il concetto di "AAA" è il pilastro di qualsiasi disciplina sistematica della sicurezza. I tre pilastri sono:

1. **Autenticazione (Authentication)** : conferma l'identità degli utenti remoti che accedono alla rete
2. **Autorizzazione (Authorization)** : assegna diritti differenziati per l'utilizzo di servizi specifici
3. **Contabilità (Accounting)** : registra tutte le operazioni di un utente durante il processo di servizio di rete per raccogliere informazioni sull'uso delle risorse di rete

13. Spiega l'autenticazione, l'autorizzazione e la contabilità nel contesto del modello AAA.

- **Autenticazione:** verifica che l'utente sia effettivamente chi dice di essere. Esempi: password, biometrici, dispositivi di sicurezza, autenticazione a più livelli. Un utente invia nome utente e password a un server AAA; se le credenziali sono corrette, il server invia un messaggio di accettazione, altrimenti invia un messaggio di rifiuto bloccando l'accesso.
- **Autorizzazione:** determina quali servizi e risorse l'utente autenticato può utilizzare. Ad esempio, un utente può essere autorizzato a leggere un file ma non a modificarlo, o a usare la stampante ma non l'accesso a Internet.
- **Contabilità:** registra (in log) tutte le attività dell'utente durante la sessione: quando si è connesso, quali risorse ha usato, quanto traffico ha generato, etc. Queste informazioni sono usate per auditing, fatturazione, analisi di sicurezza.

14. Quali forme di autenticazione esistono (biometrici, dispositivi di sicurezza, autenticazione a più livelli)?

Le forme di autenticazione menzionate sono:

- **Sistemi biometrici:** basati su caratteristiche fisiche uniche (impronte digitali, riconoscimento facciale, scansione dell'iride, riconoscimento vocale)
- **Dispositivi di sicurezza:** token hardware, smart card, chiavi USB, generatori di OTP (One-Time Password)
- **Autenticazione a più livelli (MFA – Multi-Factor Authentication)** : combinazione di due o più fattori (es. qualcosa che sai – password, qualcosa che hai – token, qualcosa che sei – biometria)

15. Come funziona il processo di autenticazione verso un server AAA?

Il processo di autenticazione verso un server AAA funziona come segue:

1. Un utente invia il proprio **nome utente e password** (o altre credenziali) a un server AAA (es. RADIUS server)
 2. Il server AAA verifica le credenziali confrontandole con un database (locale o directory centrale come LDAP/Active Directory)
 3. Se le credenziali sono **corrette**, il server AAA invia un messaggio di **accettazione** (Access-Accept) e concede l'accesso alla rete
 4. Se le credenziali sono **errate**, il server AAA invia un messaggio di **rifiuto** (Access-Reject), **bloccando l'accesso** alla rete
 5. Durante la sessione, il server AAA può anche gestire l'autorizzazione e la contabilità
-

Sezione 9.2 – Crittografia

16. Quali quattro gruppi di persone hanno storicamente contribuito all'arte della crittografia?

Storicamente quattro gruppi di persone hanno usato e dato il loro contributo all'arte della crittografia:

1. **I militari** – il ruolo più importante, hanno dato forma alla disciplina nel corso dei secoli
2. **Il corpo diplomatico** – per comunicazioni segrete tra ambasciate e governi
3. **Gli scrittori di diari** – per tenere informazioni private al sicuro
4. **Gli amanti** – per corrispondenze amorose segrete

17. Quali erano i due vincoli contrastanti nella crittografia militare tradizionale?

Nelle organizzazioni militari tradizionali, i messaggi da cifrare erano assegnati ad addetti di basso livello e bassa paga. I due vincoli contrastanti erano:

1. **Capacità degli addetti alla codifica** di riuscire a compiere le operazioni necessarie, spesso sul campo di battaglia con equipaggiamento minimo. La crittografia doveva essere abbastanza semplice da poter essere eseguita da personale non altamente specializzato.
2. **Difficoltà nel cambiare velocemente** da un metodo crittografico a un altro, perché significava dover formare una grande quantità di persone. Tuttavia, il pericolo che un addetto alla codifica potesse essere catturato rendeva essenziale la possibilità di cambiare il metodo crittografico all'istante, se necessario.

18. Cosa si intende per testo in chiaro (plaintext)?

Il **testo in chiaro (plaintext)** è il messaggio originale da cifrare, prima dell'applicazione del processo di crittografia. È il messaggio nella sua forma leggibile e comprensibile, prima di essere trasformato in testo cifrato.

19. Cosa si intende per testo cifrato (ciphertext)?

Il **testo cifrato (ciphertext)** è l'output del processo di cifratura. È il testo in chiaro trasformato tramite una funzione parametrizzata da una chiave. Il testo cifrato viene generalmente trasmesso tramite un messaggero o via radio. Un intruso che intercetta il testo cifrato non può facilmente decifrarlo senza conoscere la chiave di decifrazione.

20. Descrivi il modello di cifratura a chiave simmetrica rappresentato nella figura del capitolo.

Il modello di cifratura a chiave simmetrica (Figura 9.1 nel PDF) funziona come segue:

1. Il mittente ha un **testo in chiaro (plaintext)** e una **chiave segreta** (condivisa con il destinatario)
2. Il mittente applica una **funzione di cifratura** ($E_K(P)$) che trasforma il testo in chiaro (P) in testo cifrato (C) utilizzando la chiave (K)
3. Il **testo cifrato** viene trasmesso attraverso un canale insicuro (dove un intruso può intercettarlo)
4. Il destinatario riceve il testo cifrato e applica la **funzione di decifratura** ($D_K(C)$) utilizzando la **stessa chiave segreta** (K)
5. Il destinatario ottiene il testo in chiaro originale, con la proprietà che ($D_K(E_K(P)) = P$)

L'intruso (nemico) ascolta il canale e trascrive il testo cifrato, ma non conoscendo la chiave (K), non può decifrarlo facilmente.

21. Qual è la differenza tra intruso passivo e intruso attivo?

- **Intruso passivo**: si limita ad **ascoltare il canale di comunicazione** e a trascrivere il testo cifrato. Non altera i messaggi, si limita all'intercettazione passiva (eavesdropping).
- **Intruso attivo**: non solo ascolta, ma riesce anche a **registrare i messaggi per poi ritrasmetterli** aggiungendo informazioni oppure a **modificare i messaggi legittimi** prima che raggiungano il destinatario. Può iniettare messaggi falsi, modificare messaggi esistenti, o ritrasmettere messaggi precedentemente intercettati (attacchi replay).

22. Cosa sono la crittografia, la crittoanalisi e la crittologia?

- **Crittografia (cryptography)** : l'arte di **inventare** cifrari (metodi di cifratura)
- **Crittoanalisi (cryptanalysis)** : l'arte di **far saltare (rompere o forzare)** i cifrari
- **Crittologia (cryptology)** : il nome collettivo per l'insieme di crittografia e crittoanalisi

23. Qual è la differenza tra "decifrare" (decrypt) e "decrittare" (decipher)?

- **Decifrare (decrypt)** : operazione **legittima** di lettura di un messaggio cifrato da parte del destinatario autorizzato, utilizzando la chiave corretta. È l'operazione inversa della cifratura.
- **Decrittare (decipher)** : attività di **decifrazione da parte di un crittoanalista (intruso)** , che cerca di leggere il messaggio senza conoscere la chiave legittima.

24. Spiega la notazione $C = E_K(P)$ e $P = D_K(C)$. Cosa rappresenta?

- ($C = E_K(P)$) indica che la **cifratura** del testo in chiaro (P) usando la chiave (K) genera il testo cifrato (C). (E) è la funzione di cifratura (encryption), (K) è la chiave, (P) è il plaintext, (C) è il ciphertext.
- ($P = D_K(C)$) indica la **decifratura** di (C) per estrarre il testo in chiaro (P). (D) è la funzione di decifratura (decryption).

La proprietà fondamentale è che ($D_K(E_K(P)) = P$) (decifrare ciò che è stato cifrato con la stessa chiave restituisce il testo originale). Questa notazione suggerisce che (E) e (D) sono semplicemente delle funzioni matematiche.

25. Cos'è la crittografia simmetrica? Quale caratteristica la rende adatta per un uso diffuso?

La **crittografia simmetrica** è un metodo di codifica in cui il messaggio originale (plaintext) viene trasformato in un messaggio cifrato (ciphertext) utilizzando una **chiave segreta**. Per decifrare il ciphertext e ottenere nuovamente il plaintext, è necessaria la **stessa chiave** utilizzata per la cifratura (da cui il nome "simmetrica").

La caratteristica che la rende adatta per un uso diffuso è che **non richiede che l'algoritmo di crittografia sia tenuto segreto**; l'unica cosa che deve essere mantenuta riservata è la **chiave**. Questo permette di standardizzare gli algoritmi (es. AES, DES) e renderli pubblici, mentre la sicurezza risiede esclusivamente nella segretezza della chiave.

26. Nella crittografia simmetrica, cosa deve essere mantenuto segreto? L'algoritmo deve essere segreto?

Nella crittografia simmetrica, **solo la chiave deve essere mantenuta segreta**. L'algoritmo di crittografia stesso non deve essere segreto; anzi, gli algoritmi crittografici standardizzati (come AES) sono pubblici e ampiamente analizzati dalla comunità scientifica. La sicurezza del sistema si basa sulla **difficoltà di indovinare la chiave** (o di decifrare il messaggio senza la chiave), non sul segreto dell'algoritmo. Questo principio è noto come "Kerckhoffs' principle": un sistema crittografico dovrebbe essere sicuro anche se tutto del sistema è noto tranne la chiave.

27. Cos'è la crittografia asimmetrica? Qual è la differenza fondamentale rispetto alla crittografia simmetrica?

La **crittografia asimmetrica** (o a chiave pubblica) utilizza un sistema di crittografia in cui le operazioni di cifratura e decifratura sono eseguite con **chiavi diverse**: una **chiave pubblica** (che può essere distribuita liberamente) e una **chiave privata** (che deve essere mantenuta segreta).

La differenza fondamentale rispetto alla crittografia simmetrica è che **le chiavi per cifrare e decifrare sono diverse**: ciò che viene cifrato con la chiave pubblica può essere decifrato solo con la corrispondente chiave privata, e viceversa (in molti algoritmi). Questo elimina il problema della distribuzione della chiave (il "problema dello scambio di chiavi") che affligge la crittografia simmetrica, dove le due parti devono condividere una chiave segreta attraverso un canale sicuro.

28. A cosa servono la chiave pubblica e la chiave privata nella crittografia asimmetrica?

- **Chiave pubblica**: viene distribuita liberamente a chiunque voglia comunicare con il proprietario. Può essere usata per **cifrare** messaggi destinati al proprietario (solo il proprietario potrà decifrarli con la chiave privata), o per **verificare** le firme digitali create con la chiave privata.
- **Chiave privata**: viene mantenuta **segreta** dal proprietario. Può essere usata per **decifrare** i messaggi cifrati con la chiave pubblica, o per **firmare** digitalmente i messaggi (chiunque può verificare la firma con la chiave pubblica).

In sintesi:

- **Riservatezza (confidenzialità)** : cifrare con la chiave pubblica del destinatario (solo il destinatario può decifrare)

- **Autenticazione / non ripudio:** cifrare con la propria chiave privata (firma digitale); chiunque può verificare con la chiave pubblica del mittente

29. Su cosa si basano gli algoritmi a chiave pubblica (funzioni matematiche vs sostituzioni/permutazioni)?

Gli algoritmi a chiave pubblica si basano su **funzioni matematiche** (in particolare su problemi ritenuti computazionalmente difficili, come la fattorizzazione di grandi numeri – RSA, o il logaritmo discreto – ElGamal, Diffie-Hellman, curve ellittiche – ECC), piuttosto che su **sostituzioni e permutazioni** che sono tipiche della crittografia simmetrica classica (come nel cifrario di Cesare, Vigenère, o nei moderni algoritmi a blocchi come AES che però combinano sostituzioni e permutazioni in modo complesso). L'uso di funzioni matematiche rende possibile la sicurezza anche quando l'algoritmo è noto pubblicamente.

Sezione 9.3 – Protocolli di Autenticazione

30. Cos'è l'autenticazione nel contesto dei processi di comunicazione?

L'**autenticazione** è la tecnica usata dai processi per **verificare che la loro controparte nella comunicazione sia veramente chi indica di essere e non un impostore**. È la risposta alla domanda: "Sei veramente chi dici di essere?" La verifica dell'identità di un processo remoto, per combattere gli intrusi attivi e in malafede, è un compito sorprendentemente difficile, che richiede dei protocolli crittografici complessi.

31. Qual è la differenza tra autenticazione e autorizzazione? Fai un esempio concreto.

- **Autenticazione:** riguarda il problema di **assicurare l'identità** del processo con cui si sta comunicando ("Chi sei?"). Risponde alla domanda: "La richiesta viene veramente da un processo di Scott?"
- **Autorizzazione:** si occupa, invece, di stabilire **che cosa può fare** un processo ("Cosa ti è permesso fare?"). Risponde alla domanda: "Scott è autorizzato a cancellare ricettaio.old?"

Esempio concreto: un processo client che contatta un file server e gli comunica: "Sono il processo di Scott e voglio cancellare il file ricettaio.old". Il file server ha bisogno delle risposte a due domande:

1. La richiesta viene veramente da un processo di Scott? → **autenticazione**
2. Scott è autorizzato a cancellare ricettaio.old? → **autorizzazione**

La richiesta può essere evasa soltanto dopo che entrambe le domande hanno ottenuto una risposta certa e affermativa. Una volta che il file server sa con chi sta parlando (autenticazione), il controllo dell'autorizzazione consiste solamente in una ricerca dentro tabelle locali o in un database.

32. Perché l'autenticazione è considerata la domanda cruciale rispetto all'autorizzazione?

Una volta che il file server **sa con chi sta parlando** (ha autenticato l'utente), il controllo dell'autorizzazione consiste solamente in una ricerca dentro tabelle locali o in un database (relativamente semplice). Se invece l'autenticazione fallisce (non si è sicuri dell'identità), l'autorizzazione non può nemmeno essere valutata, perché non si sa quali privilegi attribuire a un'entità non identificata. L'autenticazione è il prerequisito fondamentale per qualsiasi controllo degli accessi basato sull'identità.

33. Cos'è l'IP spoofing? Perché l'uso dell'indirizzo IP non è un metodo di autenticazione sicuro?

L'**IP spoofing** è una tecnica in cui si creano datagrammi IP con **indirizzi IP falsi** (falsificati). Questo è possibile se si ha accesso al kernel del sistema operativo (o se si utilizza un sistema operativo che permette di impostare manualmente l'indirizzo sorgente nei pacchetti).

L'uso dell'indirizzo IP non è un metodo di autenticazione sicuro perché **chiunque può falsificare l'indirizzo IP sorgente** nei pacchetti che invia. Un attaccante può far sembrare che un pacchetto provenga da un host di fiducia quando in realtà proviene da un host malevolo. Basare l'autenticazione sull'indirizzo IP è quindi rischioso e non sufficiente in ambienti non fidati.

34. Quale problema ha l'autenticazione tramite password (es. Telnet)?

Un approccio comune per l'autenticazione è l'uso di password (come nei PIN dei dispositivi bancari o nei login dei sistemi operativi). Questo metodo **non è completamente sicuro** perché un malintenzionato può **intercettare la password** mentre viene trasmessa sulla rete. L'esempio fornito è **Telnet**, che invia la password **in chiaro** (senza crittografia). Se qualcuno monitora la rete locale (con uno sniffer), può rubare le password di login.

35. Cos'è un nonce in un protocollo di autenticazione? A cosa serve?

Un **nonce** (numero usato una sola volta) è un numero univoco che viene utilizzato **una sola volta** nel protocollo. Serve a **prevenire attacchi di replay** (ritrasmissione di messaggi vecchi). Poiché il nonce è diverso ogni volta che il protocollo viene eseguito, un attaccante che intercetta una risposta valida non può riutilizzarla in una sessione successiva (il nonce sarebbe diverso). I nonce sono tipicamente generati come numeri casuali o sequenziali.

36. Descrivi il protocollo di autenticazione basato su nonce con crittografia simmetrica.

Il protocollo di autenticazione basato su nonce con crittografia simmetrica funziona come segue:

1. Alice invia a Bob un messaggio: "**Sono Alice**" (identificazione)
2. Bob sceglie un **nonce** (R) (numero casuale) e lo invia ad Alice
3. Alice **cifra il nonce** con la sua **chiave segreta** (condivisa con Bob) e lo rimanda a Bob
4. Bob **decifra** il messaggio ricevuto con la stessa chiave segreta. Se riesce a decifrare e a **verificare che il valore ottenuto è (R)** (il nonce che ha inviato), allora Alice è **autenticata**.

Questo protocollo funziona perché solo Alice (e Bob) conoscono la chiave segreta; solo Alice poteva cifrare (R) correttamente.

37. Descrivi il protocollo di autenticazione basato su nonce con crittografia asimmetrica.

Il protocollo di autenticazione basato su nonce con crittografia asimmetrica (a chiave pubblica) funziona come segue:

1. Alice invia a Bob un messaggio: "**Sono Alice**" (identificazione)
2. Bob sceglie un **nonce** (R) e lo invia ad Alice
3. Alice **cifra il nonce** con la sua **chiave privata** e lo invia a Bob

4. Bob **decifra** il messaggio ricevuto con la **chiave pubblica di Alice**. Se ottiene il valore corretto (R), allora Alice è autenticata.

Questo protocollo è sicuro quanto il **sistema di distribuzione delle chiavi pubbliche (PKI)**. È essenziale che Bob sia sicuro che la chiave pubblica che usa per decifrare sia effettivamente quella di Alice. Se un malintenzionato riesce a sostituire la chiave pubblica di Alice con la propria (man-in-the-middle), può **spacciarsi per Alice**.

38. Da cosa dipende la sicurezza del protocollo di autenticazione a chiave pubblica?

La sicurezza del protocollo di autenticazione a chiave pubblica dipende dall'**affidabilità del sistema di distribuzione delle chiavi pubbliche (PKI – Public Key Infrastructure)**. È necessario che la chiave pubblica usata per verificare l'identità sia **autentica** (cioè appartenga veramente alla persona o entità dichiarata). Se un malintenzionato riesce a far sì che Bob usi la **chiave pubblica sbagliata** (ad esempio la propria), può **spacciarsi per Alice** (firmando il nonce con la propria chiave privata, che corrisponde a una chiave pubblica falsamente attribuita ad Alice). Per questo motivo sono necessari **certificati digitali e Autorità di Certificazione (CA)** per garantire l'associazione tra identità e chiave pubblica.

39. Cosa è OAuth2? Quali sono i suoi punti di forza e le sue vulnerabilità?

OAuth2 è un protocollo di autorizzazione (non di autenticazione, anche se spesso usato insieme all'autenticazione). Permette a un'applicazione di accedere a risorse protette su un server per conto di un utente, senza dover condividere le credenziali dell'utente.

Punti di forza:

- Semplice da implementare
- Fornisce un'autorizzazione lato server del codice (token di accesso)

Vulnerabilità:

- Vulnerabile nella gestione di diversi set di codice (alcune implementazioni)
- Può avere seri effetti sui siti connessi a un sistema compromesso

40. Cosa è RADIUS? Quali sono i suoi vantaggi e svantaggi?

RADIUS (Remote Authentication Dial-In User Service) è un protocollo AAA (Authentication, Authorization, Accounting) ampiamente utilizzato per l'accesso remoto a reti (es. dial-up, VPN, Wi-Fi enterprise).

Vantaggi:

- Meccanismo efficace per fornire accesso multiplo agli amministratori
- Assegna un'identità unica a ogni utente in una sessione

Svantaggi:

- L'implementazione iniziale può essere **complessa e costosa**
- La comunicazione tra client RADIUS (es. NAS – Network Access Server) e server RADIUS può richiedere configurazioni specifiche (shared secret, porte UDP 1812/1813)

41. Cosa è SAML? Quali sono i suoi vantaggi e svantaggi?

SAML (Security Assertion Markup Language) è un linguaggio basato su XML per lo scambio di dati di autenticazione e autorizzazione tra domini di sicurezza. È usato per il **Single Sign-On (SSO)**, dove un utente si autentica una sola volta e accede a più servizi (provider di servizi) tramite un Identity Provider (IdP).

Vantaggi:

- Riduce i costi amministrativi per gli utenti finali (non devono ricordare password multiple)
- Offre un **unico punto di accesso** per autenticarsi attraverso vari fornitori di servizi

Svantaggi:

- Dipende **fortemente dal fornitore di identità (IdP)**: se l'IdP è giù, nessun servizio è accessibile
- Gestisce tutti i dati in un unico formato **XML** (che può essere verbose e pesante)
- La configurazione può essere complessa

Sezione 9.4 – Certificati Digitali

42. A cosa servono i certificati digitali?

I **certificati digitali** servono a **legare un'identità (persona, organizzazione, server) a una chiave pubblica** in modo verificabile e trustato. Sono l'infrastruttura che rende sicuro l'uso della crittografia asimmetrica, perché permettono a una parte di essere sicura che una determinata chiave pubblica appartenga effettivamente alla controparte dichiarata. I certificati sono rilasciati e firmati da un'entità fidata chiamata **Autorità di Certificazione (CA – Certification Authority)**.

43. Cosa contiene tipicamente un certificato digitale?

Un certificato digitale (es. X.509) contiene tipicamente:

- **Informazioni sull'identità del soggetto** (nome, organizzazione, paese, etc.)
- **Chiave pubblica del soggetto**
- **Periodo di validità** (data di inizio e fine)
- **Informazioni sul certificatore (CA)** che ha emesso il certificato
- **Numero di serie** (univoco)
- **Algoritmo di firma** utilizzato
- **Firma digitale** della CA sull'intero certificato (hash del certificato cifrato con la chiave privata della CA)

44. Cos'è un hash firmato in relazione a un certificato?

Un **hash firmato** (o firma digitale) in un certificato è il risultato di:

1. Calcolare l'**hash** (impronta digitale) del certificato (escluso il campo della firma stessa) con una funzione di hash crittografico (es. SHA-256)
2. **Cifrare l'hash** con la **chiave privata della CA** che ha emesso il certificato
3. Il risultato è la **firma digitale** del certificato

Chiunque possieda la **chiave pubblica della CA** (che è pre-installata e considerata fidata) può verificare che il certificato non è stato alterato decifrando la firma, ricalcolando l'hash del certificato, e confrontando i due valori. Se corrispondono, il certificato è autentico e integro.

45. Quale ente rilascia e firma i certificati digitali?

I certificati digitali sono rilasciati e firmati da un'**Autorità di Certificazione (CA – Certification Authority)**. Le CA sono enti fidati (es. DigiCert, Let's Encrypt, GlobalSign, IdenTrust, e molte altre) che verificano l'identità di chi richiede un certificato prima di rilasciarlo. I browser e i sistemi operativi includono una lista di CA fidate (trust store) con le loro chiavi pubbliche pre-installate, che permette di verificare la catena di fiducia dei certificati.

46. Qual è il ruolo dell'Autorità di Certificazione (CA) nella gestione dei certificati?

L'**Autorità di Certificazione (CA)** ha un ruolo centrale nella PKI (Public Key Infrastructure):

1. **Verifica l'identità** del richiedente (con diversi livelli di validazione: DV – Domain Validation, OV – Organization Validation, EV – Extended Validation)
2. **Genera o approva** la coppia di chiavi (o ne verifica il possesso)
3. **Rilascia il certificato** firmandolo con la propria chiave privata
4. **Mantiene una lista di revoche** (CRL – Certificate Revocation List) o fornisce servizi OCSP (Online Certificate Status Protocol) per indicare quali certificati non sono più validi (es. chiave compromessa, certificato scaduto, etc.)
5. **Garantisce l'affidabilità** della catena di fiducia: il certificato della CA radice è auto-firmato e distribuito nei trust store dei client

Domande trasversali e di confronto

47. Confronta crittografia simmetrica e asimmetrica in termini di: numero di chiavi, distribuzione delle chiavi, utilizzo tipico.

Caratteristica	Crittografia Simmetrica	Crittografia Asimmetrica
Numero di chiavi	Una chiave (condivisa)	Due chiavi per entità (pubblica + privata). Per comunicazione bidirezionale tra N parti, servono $2N$ chiavi (N pubbliche + N private)
Distribuzione delle chiavi	Problema difficile: le due parti devono condividere la chiave segreta tramite un canale sicuro (o incontrandosi fisicamente)	Facilitata: le chiavi pubbliche possono essere distribuite liberamente anche su canali insicuri; la chiave privata rimane segreta. Serve PKI/Certificati per l'autenticità
Utilizzo tipico	Cifratura di grandi quantità di dati (file, dischi, comunicazioni bulk) perché gli algoritmi simmetrici (es. AES) sono molto più veloci	Scambio di chiavi (es. Diffie-Hellman, RSA per cifrare chiave simmetrica), firme digitali (autenticazione, non ripudio), cifratura di piccoli dati (es. chiavi di sessione)

48. Confronta i protocolli di autenticazione OAuth2, RADIUS e SAML in termini di: complessità di implementazione, gestione delle identità, formato dei dati.

Caratteristica	OAuth2	RADIUS	SAML
Complessità implementazione	Semplice (sono disponibili librerie per molti linguaggi)	Complessa (infrastruttura client-server, configurazione shared secret, porte UDP specifiche)	Complessa (gestione XML, configurazione IdP e SP, metadati)
Gestione delle identità	Basata su token e scopes; delega l'autenticazione a un Identity Provider (es. Google, Facebook, Auth0)	Centralizzata su server RADIUS; utenti in database locale/LDAP/Active Directory	Centralizzata su Identity Provider (IdP); funziona con directory esistenti (LDAP, Active Directory)
Formato dei dati	Token in JSON (JWT – JSON Web Tokens) o stringhe opache; comunicazione su HTTP/HTTPS (API REST)	Pacchetti UDP (porta 1812/1813) con attributi codificati in formato RADIUS (RFC 2865/2866)	XML (SOAP) over HTTP/HTTPS

49. Spiega la relazione tra autenticazione, autorizzazione e contabilità nel modello AAA.

Nel modello **AAA** (Authentication, Authorization, Accounting), i tre pilastri sono in sequenza logica:

1. **Autenticazione (Authentication)** : primo passo. L'utente dimostra la propria identità (es. fornendo credenziali). Il sistema verifica che l'utente sia chi dice di essere. Se fallisce, il processo si ferma.
2. **Autorizzazione (Authorization)** : secondo passo. Una volta autenticato, il sistema determina **quali risorse e servizi** l'utente può utilizzare e **quali operazioni** può eseguire (es. leggere file, stampare, accedere a Internet). L'autorizzazione si basa su politiche e liste di controllo degli accessi (ACL).
3. **Contabilità (Accounting)** : terzo passo (parallelo). Durante l'uso dei servizi, il sistema **registra** le attività dell'utente: orario di connessione, disconnessione, risorse utilizzate, quantità di dati trasferiti, etc. Questi log servono per auditing, fatturazione (billing), analisi di sicurezza, e forensic.

50. Perché il controllo degli accessi basato esclusivamente sull'indirizzo IP non è considerato sicuro?

Il controllo degli accessi basato esclusivamente sull'indirizzo IP non è considerato sicuro per le seguenti ragioni:

1. **IP spoofing**: gli indirizzi IP possono essere **falsificati** (spoofed). Un attaccante può creare pacchetti con un indirizzo IP sorgente falso, facendoli sembrare provenienti da un host fidato.
2. **Assenza di autenticazione**: l'indirizzo IP non autentica la persona o il processo; autentica solo la posizione di rete, che può essere condivisa (es. NAT) o può essere compromessa (es. un host fidato che viene infettato).
3. **Dinamicità**: molti indirizzi IP sono **assegnati dinamicamente** (DHCP). Un utente legittimo oggi potrebbe avere un IP diverso domani, e un attaccante potrebbe ottenere lo stesso IP che era di un

utente fidato.

4. **NAT**: migliaia di dispositivi possono condividere lo stesso indirizzo IP pubblico (NAT). Non si può distinguere quale dispositivo specifico sta facendo la richiesta.
5. **Man-in-the-middle**: un attaccante sulla stessa rete locale (o che controlla un router) può intercettare e modificare il traffico, indipendentemente dall'indirizzo IP.

Per questi motivi, l'indirizzo IP può essere usato come **fattore aggiuntivo** (es. per restrizioni geografiche o whitelisting in contesti limitati), ma non come unico meccanismo di autenticazione o controllo degli accessi in ambienti sensibili.